

행정안전부 소관 주요정보통신기반시설 보호지침 개정(안)

제정 2013. 9. 6. 안전행정부훈령 제18호

개정 2014. 11. 25. 행정자치부훈령 제 1호

개정 2017. 9. 21. 행정안전부훈령 제 7호

개정 2021. 3. 5. 행정안전부훈령 제186호

개정 2026. 2. 2. 행정안전부훈령 제423호

제1장 총칙

제1조(목적) 이 지침은 「정보통신기반 보호법」 제10조에 따라 행정안전부 장관이 관할하는 주요정보통신기반시설을 각종 전자적 침해행위로부터 보호하기 위하여 해당 주요정보통신기반시설 관리기관의 장이 준수하여야 할 구체적 사항을 정함을 목적으로 한다.

제2조(용어의 정의) ① 이 지침에서 사용하는 용어의 정의는 다음과 같다.

1. "주요정보통신기반시설 보호대책"이라 함은 법 제5조제1항에서 규정에 의하여 각 관리기관의 주요정보통신기반시설 및 관리정보를 안전하게 보호하기 위한 예방, 백업, 복구 등 물리적·기술적 대책을 포함한 관리기관별 관리대책을 말한다.
2. "주요정보통신기반시설 보호계획"이라 함은 법 제5조제2항의 규정에 의하여 관리기관으로부터 제출받은 주요정보통신기반시설보호대책을 종합·조정한 행정안전부 소관 주요정보통신기반시설에 관한 보호계획을 말한다.
3. "정보공유·분석센터"라 함은 법 제16조에 따라 분야별 주요정보통신기반시설을 보호하기 위해 취약점 및 대응방안에 관한 정보 제공, 실시간 경보·분석체계 운영 등을 수행하는 조직을 말한다.
4. "관리기관"이라 함은 법 제8조의 규정에 의하여 지정된 주요정보통신기반시설을 책

임과 권한을 가지고 보호대책의 수립 및 시행하는 기관(부서)을 말한다.

② 이 지침에서 사용하는 용어의 정의는 제1항에서 정한 것을 제외하고는 정보통신기반보호법에서 정하는 바에 따른다.

제3조(적용범위) 이 지침은 「정보통신기반 보호법(이하 "법"이라 한다)」 제8조에 따라 행정안전부 장관이 지정 고시한 주요정보통신기반시설을 관리하는 기관(이하 "관리기관"이라 한다)과 해당 주요정보통신기반시설을 운영하는 기관 또는 부서의 업무종사자에 적용한다.

제2장 정보보호체계 및 관리

제4조(정보보호책임관) ① 법 제6조제5항에 따른 행정안전부 정보보호책임관은 행정안전부 인공지능정부기반국의 주요정보통신기반시설 보호업무를 담당하는 고위공무원으로 한다.

② 정보보호책임관은 행정안전부 장관이 관할하는 소관분야 및 지방자치단체의 모든 주요정보통신기반시설의 보호에 관한 업무를 총괄한다.

③ 정보보호책임관은 「정보통신기반보호법 시행령(이하 "시행령"이라 한다)」 제11조 제2항에서 규정하는 보호업무를 수행한다.

④ 정보보호책임관은 주요정보통신기반시설 관리의 효율성 및 기반시설 보호의 수행능력 등을 고려하여 해당 주요정보통신기반시설을 관리하는 기관(이하 "관리기관"이라 한다)을 정하여야한다. 다만, 지방자치단체의 장이 관리·감독하는 주요정보통신기반시설의 관리기관은 광역자치단체와 협의하여 정할 수 있다.

제5조(정보보호책임자) ① 관리기관의 장은 시행령 제9조제1항에 따라 소관 주요정보통신기반시설 보호에 관한 업무를 담당하는 4급·4급상당 공무원, 5급·5급상당 공무원, 영관급장교 또는 임원급 관리자를 정보보호책임자로 지정하여야 한다.

② 정보보호책임자는 시행령 제9조제2항에서 규정하는 업무를 총괄 수행한다.

③ 관리기관의 장은 정보보호책임자를 지정하거나 변동사항이 발생한 경우에는 15일

이내에 행정안전부 장관 및 광역자치단체 정보보호책임자에게 이를 통지하여야 한다.

④ 정보보호책임자는 소관 주요정보통신기반시설 보호를 위하여 정보보호책임관 및 정보보호실무책임자와 긴밀히 협조하여야 한다.

⑤ 정보보호책임자는 소관 주요정보통신기반시설의 보호를 위하여 기반시설의 특성, 운용환경 등을 고려한 자체 기반시설 보안전침을 제정하여야 한다.

⑥ 광역자치단체의 정보보호책임자는 관할구역 내 지방자치단체의 장이 관리·감독하는 주요정보통신기반시설의 보호업무를 총괄하며, 다음 각 호의 업무를 수행한다.

1. 법 제8조제4항에 따라 지방자치단체의 장이 관리·감독하는 시설에 대한 주요정보통신기반시설 지정·취소 지원에 관한 업무
 2. 법 제5조제3항에 따른 주요정보통신기반시설 보호대책(이하 "보호대책"이라 한다) 제출 및 검토에 관한 업무
 3. 주요정보통신기반시설의 침해사고 대응 및 복구 지원에 관한 업무
 4. 주요정보통신기반시설의 취약점 분석·평가 지원 및 침해사고 예방·지원 업무
 5. 주요정보통신기반시설의 정보보호 조직·체계 구축·운영 지원에 관한 업무
 6. 보호대책 이행 등을 위한 정보보호 시설·장비 등의 구축 지원에 관한 업무
 7. 주요정보통신기반시설 취약점 분석·평가 등 보호 관련 예산 확보 지원에 관한 업무
 8. 주요정보통신기반시설 정보보호 실태 점검 및 개선에 관한 업무
 9. 주요정보통신기반시설의 정보보호 활동의 지도 및 감독
 10. 주요정보통신기반시설의 외부 보안점검 수검 지원에 관한 업무
 11. 그 외에 주요정보통신기반시설 보호를 위하여 행정안전부 정보보호책임관이 협조 요청한 사항 등
- ⑦ 광역자치단체 정보보호책임자는 주요정보통신기반시설을 보호하기 위해 필요시 행정안전부 장관에게 기술지원을 요청할 수 있다.

제5조2(정보보호실무책임자) ① 관리기관의 장은 효율적인 보호업무 수행을 위해 주요정보통신기반시설을 운영하는 기관(부서)의 5급·5급상당 이상의 공무원, 부장급 또는 과장급 관리자를 정보보호실무책임자로 지정하여야 한다. 다만, 주요정보통신기반시설이 하나인 관리기관은 정보보호책임자가 정보보호실무책임자를 겸할 수 있다.

② 정보보호책임자는 효율적인 업무수행을 위하여 정보보호실무책임자에게 다음 업무를 수행하게 할 수 있다.

1. 소관 주요정보통신기반시설에 대한 차년도 보호대책 수립의견 제출
 2. 소관 주요정보통신기반시설에 대한 당해년도 보호대책 추진과제에 대한 조치 및 과제별 추진실적의 제출
 3. 소관 주요정보통신기반시설의 취약점에 대한 조치 및 결과의 제출
 4. 소관 주요정보통신기반시설에 대한 보안정책의 적용·관리, 보안점검 및 조치활동 수행, 용역업체 보안관리 활동 수행
 5. 그 외에 주요정보통신기반시설 보호를 위하여 정보보호책임자가 협조 요청한 사항 등
- ③ 관리기관의 장은 정보보호실무책임자를 지정하거나 변동사항이 발생한 경우에는 별표 3의 양식을 활용하여 15일 이내에 행정안전부 장관 및 광역자치단체 정보보호책임자에게 이를 통지하여야 한다.

제6조(세부시설의 지정) ① 관리기관의 장은 주요정보통신기반시설로 지정하기 위한 업무별로 기본단위(이하 "지정단위"라 한다)를 선정하여야 하며, 지정단위별로 전체 시스템을 세부시설로 지정하여야 한다. 이때 별표9에서 정하는 기준을 고려하여야 한다.

② 정보보호책임자는 년 1회 이상 주요정보통신기반시설로 지정된 세부시설의 적정성 여부 등을 검토하여야 한다.

③ 정보보호책임자는 제1항 및 제2항에 따라 변동사항이 발생한 경우 자산 관리대장에 등록하여 관리해야 하며 기반시설 보호대책 수립시 반영하여야 한다.

제6조의2(자산 관리) ① 정보보호책임자는 주요정보통신기반시설로 지정된 시설의 자산 현황을 총괄 관리하여야 한다. 다만, 운영기관별 세부 자산현황은 정보보호실무책임자가 관리하여야 한다.

② 자치단체 정보공유·분석센터의 장은 정보보호책임자에게 주요정보통신기반시설 세부시설의 자산 및 인력 등의 자료 제출을 요청할 수 있다.

③ 정보보호책임자는 주요정보통신기반시설로 지정된 시설의 자산에 장비현황 라벨을

별표 8의 양식을 활용하여 부착하여야 한다. 다만, 운영기관별 장비현황 라벨은 정보 보호실무책임자가 부착하여야 한다.

④ 정보보호책임자는 주요정보통신기반시설의 효율적인 관리를 위하여 장비별 정·부담당자를 지정하여야 한다. 다만, 운영기관별 담당자는 정보보호실무책임자가 지정한다.

제7조(정보보호책임자협의회) ① 행정안전부 장관은 주요정보통신기반시설 보호와 관련된 다음 사항을 협의하기 위해 정보보호책임자협의회(이하"협의회"라 한다)를 구성·운영할 수 있다.

1. 주요정보통신기반시설 보호계획(이하 "보호계획"이라 한다) 및 보호대책 검토
2. 주요정보통신기반시설의 지정 및 취소, 지정 범위 조정
3. 주요정보통신기반시설 보호 관련 제도 개선
4. 보호대책 이행점검 결과에 따른 후속조치 및 이행률 제고방안
5. 주요정보통신기반시설 점검에 따른 미흡사항 조치방안
6. 주요정보통신기반시설 사이버침해사고 예방 및 대응조치
7. 그 외 주요정보통신기반시설 보호와 관련하여 협의가 필요한 사항 등

② 제1항에 따른 협의회회의 의장은 행정안전부의 실·국장급 공무원으로 하고, 간사는 제4조에 따른 정보보호책임관으로 하며, 위원은 제5조에 따른 정보보호책임자로 한다. 다만, 의장이 필요하다고 인정하는 경우에는 한국인터넷진흥원 등의 정보보호전문가를 위원으로 위촉할 수 있다.

③ 협의회는 매년 상·하반기 등 년 2회 정기적으로 개최하며, 필요시 수시로 개최할 수 있다.

제8조(전담 조직의 구성) 관리기관의 장은 제5조제2항에 따른 주요정보통신기반시설 보호 업무를 수행하기 위하여 정보보호책임자 소속 하에 별도의 전담 조직을 구성·운영할 수 있다.

제9조(업무종사자의 준수사항) ① 관리기관의 장은 소관 주요정보통신기반시설을 관

리·운영하는 업무종사자(계약직을 포함한다)로 하여금 다음 각 호의 사항을 준수하도록 하여야 한다.

1. 주요정보통신기반시설의 보호책임에 관한 사항
2. 비밀유지 및 비밀서약에 관한 사항
3. 주요정보통신기반시설 보호관련 법령 및 지침 등의 준수에 관한 사항
4. 보호관련 지침 및 보호조치 위반에 따른 징계에 관한 사항

② 관리기관의 장은 해당 시설을 관리·운영하는 업무종사자가 보직이 변경되거나 퇴사하는 경우 법 제27조에 따라 소관 주요정보통신기반시설의 관리·운영에 관하여 취득한 비밀을 외부에 유출하지 않도록 주지시켜야 한다. 이 경우 관리기관의 장은 보직이 변경되거나 퇴사하는 자에 대하여 비밀유지에 관한 서약서를 작성하도록 요구할 수 있다.

제10조(보호업무 등의 위탁) 관리기관의 장은 소관 주요정보통신기반시설의 관리·운영 또는 취약점 분석·평가 등 보호에 관한 업무를 전문기관 또는 업체에 위탁하는 때에는 해당 기관 또는 업체의 위탁업무 수행에 참여하는 종사자에게 법 제27조에 따른 비밀유지의무를 준수하도록 비밀유지 서약서의 작성 요구, 업무관련 기록·자료의 안전한 보존 및 폐기 등 필요한 조치를 하여야 한다.

제11조(유관기관과의 협조) 관리기관의 장은 소관 주요정보통신기반시설의 보호를 위하여 행정안전부, 한국인터넷진흥원, 자치단체 정보공유·분석센터 또는 다른 관리기관과 다음 각 호의 사항에 관하여 상호 협조할 수 있다.

1. 주요정보통신기반시설의 보호와 관련된 정보의 공유
2. 침해사고 예방·대응 및 복구를 위한 상호협력 및 지원
3. 취약점 및 침해요인과 관련된 정보의 공유
4. 그 밖에 소관 주요정보통신기반시설의 보호를 위하여 상호협력이 필요한 사항

제12조(정보보호 교육·모의훈련의 실시) ① 관리기관의 장은 소관 주요정보통신기반시설의 정보보호업무를 수행하는 담당자를 대상으로 해당 시설의 보호를 위하여 필요

한 정보보호 교육을 연간 40시간 이상 이수하도록 하여야 하며, 침해사고 모의훈련을 매년 1회 이상 실시하여야 한다.

② 관리기관의 장은 소관 주요정보통신기반시설의 보호를 위한 중요한 절차·방법, 담당인력 등의 변경이 있거나 침해사고가 발생되었을 경우에는 필요한 교육·훈련을 실시하여야 한다.

③ 관리기관의 장은 제22조 및 제23조에 따른 침해사고 대응·복구에 관한 절차 및 방법을 숙지하기 위해 침해사고 모의훈련을 실시하고 필요한 경우 해당 대응·복구절차 및 방법을 수정·보완하여야 한다.

제13조(정보보호 활동 지원) 행정안전부 장관은 주요정보통신기반시설 및 주요정보통신기반시설과 연계된 시설의 안정성 및 신뢰성을 위하여 관리기관에 대하여 다음 각 호의 사항을 지원할 수 있다.

1. 모의 해킹을 통한 취약점 분석 및 그 조치방안에 대한 지원
2. 보호대책 수립·이행에 대한 지원
3. 관계기관 비상연락체계 구축 및 사이버공격 발생 시 대응·복구 지원
4. 그 밖에 주요정보통신기반시설 보호를 위하여 지원이 필요한 사항

제3장 보호대책 수립·이행

제14조(보호대책의 수립) ① 관리기관의 장은 법 제5조제1항에 따라 수립한 보호대책을 매년 8월말까지 행정안전부 장관에게 제출하여야 한다. 다만, 지방자치단체 관리기관의 보호대책은 광역자치단체의 장이 취합하여 행정안전부 장관에게 제출하여야 한다.

② 관리기관의 장은 보호대책을 수립할 때에 시행령 제10조제2항에 따라 행정안전부 장관으로부터 통보받은 보호대책 수립지침을 준수하여야 하며, 법 제9조에 따라 실시한 취약점 분석·평가 결과를 반영하여야 한다.

③ 행정안전부 장관은 필요할 경우 관리기관으로 하여금 제1항에 따른 보호대책 제출 시 취약점 분석·평가 결과를 함께 제출하도록 할 수 있다.

④ 행정안전부 장관은 취약점 분석·평가 결과 등을 고려하여 필요할 경우 관리기관의 장에게 보호대책을 보완하도록 요청할 수 있다.

제15조(보호대책 이행) ① 행정안전부 장관은 법 제6조 및 시행령 제10조제3항에 따라 정보통신기반보호위원회에서 심의·확정한 행정안전부 소관 보호계획을 심의일로부터 15일 이내에 소관 관리기관에 통보해야 한다.

② 관리기관의 장은 제1항에 따라 통보받은 보호계획과 제14조에 따라 수립한 보호대책을 이행하여야 한다.

제16조(이행점검) ① 행정안전부 장관은 법 제6조에 따른 보호계획을 수립하기 위해 전년도 보호대책을 제출·이행한 관리기관을 대상으로 해당 보호대책에 대한 이행점검을 실시할 수 있다.

② 행정안전부 장관은 직접 이행점검을 실시하거나 관리기관으로 하여금 자체적으로 이행점검을 한 후 그 결과를 행정안전부 장관에게 제출하도록 할 수 있다. 이 때, 지방자치단체 관리기관에 대해서는 광역자치단체의 장이 이행점검을 실시한 후 그 결과를 행정안전부 장관에게 제출하여야 한다.

③ 행정안전부 장관은 관리기관 보호대책의 이행에 따른 기관별 보호조치의 세부적인 내용을 별도로 확인·점검할 수 있다.

④ 행정안전부 장관은 관리기관별 보호대책의 추진현황, 시스템 운영관리 및 정보보호에 관한 사항을 점검할 수 있다. 이때 행정안전부 장관은 한국인터넷진흥원 및 자치단체 정보공유·분석센터로 하여금 점검을 수행하도록 할 수 있다.

제17조(취약점 분석·평가) ① 관리기관의 장은 법 제9조 및 시행령 제17조 및 제18조에 따라 소관 주요정보통신기반시설에 대한 취약점 분석·평가를 매년 실시해야 한다.

② 관리기관의 장은 취약점 분석·평가를 실시할 때에는 법 제9조제4항의 기준 등을 고려하여 대상, 기간, 절차, 방법 등 필요한 세부 계획을 수립·이행하여야 한다.

③ 관리기관의 장은 법 제9조제3항에 따라 다음 각호의 1에 해당하는 기관으로 하여금 소관 주요정보통신기반시설의 특성 등을 고려하여 취약점 분석·평가를 하게 할 수 있다.

1. 한국인터넷진흥원

2. 지방자치단체 정보공유·분석센터

3. 정보보호 전문서비스기업

4. 한국전자통신연구원

④ 관리기관의 장은 취약점 분석·평가시 발견된 사항의 조치를 위하여 항목별 조치현황을 별표 5의 양식을 활용하여 관리대장에 기록·관리하여야 한다.

⑤ 행정안전부 장관은 소관 정보통신기반시설을 주요정보통신기반시설로 신규 지정할 때에는 최초로 수행하는 취약점 분석·평가에 대해 관리기관을 지원할 수 있다.

제18조(자체 점검 및 수시점검) ① 관리기관의 장은 시행령 제17조제2항에 따라 취약점 분석·평가가 필요하다고 판단되는 경우에는 1년이 되지 아니한 때에도 소관 주요정보통신기반시설에 대한 자체 점검을 실시할 수 있다.

② 관리기관의 장은 다음 각 호의 어느 하나에 해당하는 경우에는 수시로 점검(이하 "수시점검"이라 한다)을 실시할 수 있다.

1. 침해사고의 징후가 있는 경우

2. 시설·장비의 교체 및 보수를 한 경우

3. 침해사고에 따른 복구조치를 한 경우

4. 소관 주요정보통신기반시설의 보호에 관한 절차·방법 및 담당 인력의 변경이 있는 경우

③ 관리기관의 장은 제1항과 제2항에 따른 자체 점검 및 수시점검을 실시할 때에는 다음 각 호의 사항을 고려하여 실시하여야 한다.

1. 법 제9조에 따른 취약점 분석·평가 기준

2. 취약점 분석·평가의 범위 및 항목, 절차, 방법

3. 이전에 실시한 취약점 분석·평가의 결과

④ 관리기관의 장은 자체 점검 및 수시점검을 실시한 때에는 점검 기간, 대상, 방법 및 결과 등 점검에 관한 제반사항을 기록·관리하여야 한다.

⑤ 관리기관의 장은 소관 주요정보통신기반시설의 보안관리 실태를 별표 6의 양식을

활용하여 월 1회 이상 자체점검을 실시하여야 한다.

제19조(보완조치) 관리기관의 장은 제16조에 따른 보호대책 이행실적의 점검, 제17조에 따른 취약점 분석·평가 및 제18조에 따른 점검 결과를 반영하여 다음 각 호의 조치를 하여야 한다.

1. 주요정보통신기반시설보호를 위해 수립된 각종 보호조치, 절차 및 방법 등의 재검토 및 수정·보완

2. 주요정보통신기반시설의 취약항목 개선, 보안장비 구축, 백신설치, 시스템 구조개선 등 보완 조치

3. 그 밖에 취약점 분석·평가 또는 점검 결과를 반영한 보완 조치

제4장 침해사고에 대한 대응 및 복구

제20조(연락체계의 구축) ① 관리기관의 장은 소관 주요정보통신기반시설에 대한 전자적 침해사고가 발생한 경우 신속히 대응하고 관계기관에 알리기 위해 필요한 연락체계를 구축하여야 한다.

② 관리기관의 장은 제1항에 따른 연락체계에 있어 행정안전부 정보보호책임관과 국가정보원, 한국지역정보개발원의 자치단체 정보공유·분석센터, 한국인터넷진흥원, 수사기관이 포함되도록 하여야 한다. 이 때, 지방자치단체 관리기관의 경우에는 해당 광역자치단체 정보보호책임자도 포함하여야 한다.

제21조(침해사고의 통지) ① 관리기관의 장은 침해사고가 발생하여 소관 주요정보통신기반시설이 교란·마비 또는 파괴된 사실을 인지한 때에는 법 제13조제1항에 따라 행정안전부와 국가정보원, 자치단체 정보공유·분석센터, 수사기관 또는 한국인터넷진흥원에 그 사실을 별표 10의 양식을 활용하여 통지하여야 한다. 이 때, 지방자치단체 관리기관의 경우에는 해당 광역자치단체 정보보호책임자에게도 통지하여야 한다.

② 제1항에 의한 침해사고의 통지에는 다음 각 호의 사항이 포함되어야 한다.

1. 침해사고발생 일시 및 시설

2. 침해사고로 인한 피해내역, 조치현황

3. 기타 신속한 대응·복구를 위하여 필요한 사항

제22조(침해사고 대응조치) ① 기반시설을 관리 또는 운영하는 기관의 임직원 및 유지보수업체의 수탁업무 수행에 참여하는 종사자는 전자적 침해사고의 징후가 있거나 전자적 침해사고의 발생을 인지한 때에는 이를 즉시 정보보호책임자에게 보고하고 침해사고대응팀 구성 등 필요한 응급조치를 취하여야 한다.

② 정보보호책임자는 소관 주요정보통신기반시설에 대한 중대한 전자적 침해사고의 발생·징후를 보고 받거나 인지한 때에는 이를 행정안전부에 즉시 보고하여야 한다. 다만, 관리기관의 장은 소관 주요정보통신기반시설의 교란, 마비 또는 파괴가 일어나지 아니하는 등 경미한 침해사고의 발생·징후는 조치하고 이를 사후보고할 수 있다.

③ 관리기관의 장은 제1항 및 제2항에 따른 사항을 포함하여 전자적 침해사고 발생에 따른 대응절차 및 방법 등 침해사고 대응체계를 수립하여야 한다. 이 경우 별표 1에서 정하는 사항을 고려하여야 한다.

④ 행정안전부 장관은 관리기관에게 침해사고 대응요령을 권고할 수 있으며, 관리기관은 자체 사이버위기대응매뉴얼을 수립하고 이에 따라 피해사실의 보고 및 긴급대응조치 등을 하여야 한다.

⑤ 행정안전부 장관은 소관 주요정보통신기반시설에 침해사고가 발생한 때에는 자치단체 정보공유·분석센터를 통하여 대응조치를 수행하도록 할 수 있다.

제23조(침해사고 복구조치) ① 관리기관의 장은 소관 주요정보통신기반시설에 대한 침해사고가 발생한 때에는 해당 정보통신기반시설의 복구 및 보호에 필요한 조치를 신속히 취하여야 한다. 이 때, 행정안전부 장관 또는 자치단체 정보공유·분석센터, 한국인터넷진흥원의 장에게 지원을 요청할 수 있다.

② 관리기관의 장은 제1항의 복구조치를 위하여 필요한 조직, 자원, 외부기관과의 협력 등을 포함하는 복구지원체계를 구축하여야 한다.

③ 관리기관의 장은 제1항 및 제2항의 내용을 포함하여 전자적 침해사고가 발생한 시설에 대한 복구절차 및 방법에 관하여 필요한 사항을 정하여야 한다. 이 경우 별표 2에서 정하는 사항을 고려하여야 한다.

제5장 기술적 보호조치

제24조(침해사고 예방조치) 관리기관의 장은 소관 주요정보통신기반시설을 보호하기 위하여 침해사고 예방대책을 수립·시행하는 경우에는 다음 각 호의 사항을 고려하여야 한다.

1. 시스템·네트워크 관리 및 보호에 관한 대책
2. 정보보호시스템 설치·운용에 관한 대책
3. 전산자료에 대한 백업조치 및 복구대책 등
4. 악성코드 방지 대책
5. 접근통제에 관한 대책
6. 그 밖에 소관 주요정보통신기반시설의 침해사고 예방을 위해 필요한 사항

제25조(정보통신망 보안관리) ① 관리기관의 장은 소관 주요정보통신기반시설 보호를 위하여 타 정보통신망과 분리·운영, 인터넷 연결이 차단된 관리자PC를 통한 시스템 관리기능 접속, 비인가 단말기 접속차단 등의 기술적 통제수단을 강구하여야 한다.

② 관리기관의 장은 소관 주요정보통신기반시설 관련 서버, 단말기, 네트워크 장비 등에 불필요한 서비스·사용자 계정 등은 제거하고 유지보수를 위한 외부업체의 원격관리를 금지하여야 한다.

③ 관리기관의 장은 소관 주요정보통신기반시설 보호를 위하여 시스템별 사용자접근, 사용내역 등의 로그자료를 1년 이상 보관하는 등 기록을 유지하여야 한다.

제26조(제어시스템 보안관리) ① 관리기관의 장은 주요정보통신기반시설 중 제어시스템의 보호를 위하여 제어시스템이 포함된 정보통신망을 폐쇄망으로 운영하여야 한다. 다만, 업무시스템 등과의 연결이 불가피할 경우 해당 구간에 일방향통신장비 설치 등 제어시스템을 내부 업무망 등과 분리·운영하여야 한다.

② 관리기관의 장은 주요정보통신기반시설 중 제어시스템 관련 서버 및 단말기 등을 대상으로 USB, CD, DVD 등 보조기억매체 사용 통제, 보안패치 적용, 바이러스 백신 설치 등의 악성코드 감염 및 자료 유출 방지대책을 마련·시행하여야 한다.

③ 관리기관의 장은 제어시스템 단말기는 망간 혼용사용을 금지하고, 제어망 내 자료이동이 불가피할 경우 광디스크(CD/DVD) 사용 등을 통해 백신 검사 후 자료이동을 실시하여야 한다.

제27조(외부 용역사업 보안관리) ① 관리기관의 장은 주요정보통신기반시설 관련 정보화사업 및 보안컨설팅 수행 등 외부 용역사업 계약 시 보안서약서를, 종료 시 보안확약서를 징구하고 다음 각 호의 사항을 계약서에 명시하여야 한다.

1. 중요 정보 취급에 대한 비밀 유지 서약
2. 외주 업체가 준수해야 할 보안준수 사항 및 위반시 손해배상 책임
3. 정보시스템 접근 권한에 대한 승인 절차 준수
4. 보안관리에 대한 감사 권한 등
5. 누출금지 대상정보 및 부정당업자의 제재조치
6. 참여인력의 임의교체 금지

② 관리기관의 장은 용역업체의 전산망을 주요정보통신기반시설망 및 기관 업무망과 분리 구성하여야 하며 용역업체 직원이 사용하는 PC는 인터넷 연결을 금지하여야 한다. 다만, 인터넷 연결이 필요한 경우에는 별도의 PC를 지정하여 제한적으로 이용하도록 관리기관이 통제하여야 한다.

③ 관리기관의 장은 용역업체 직원의 계정을 개인별로 부여하고 계정별로 정보시스템 접근권한을 차등 부여하여야 한다.

④ 관리기관의 장은 주요정보통신기반시설 용역사업에 대해 별표 7의 양식을 활용하여 분기 1회 이상 보안점검을 실시하고 용역사업 참여업체 직원에 대하여 분기 1회 이상 보안교육을 실시하여야 한다.

제6장 기타

제28조(준용) 관리기관의 장은 주요정보통신기반시설 보호 업무를 수행함에 있어 이 지침에 명시되지 않은 사항은 다음 관련 규정 및 지침 등에 따른다.

1. 「전자정부법」 및 같은 법 시행령

2. 「정보시스템 저장매체 불용처리지침」

3. 「보안업무규정」

4. 「국가정보보안기본지침」

5. 「국가사이버안전관리규정」

6. 그 밖에 정보보호 관련 법령 및 지침·가이드·매뉴얼

부칙 <제1호, 2014.11.25>

제1조(시행일) 이 지침은 발령한 날부터 시행한다.

제2조(재검토기한) 행정안전부 장관은 이 훈령에 대하여 「훈령·예규 등의 발령 및 관리에 관한 규정」에 따라 2026년 1월 1일 기준으로 매3년이 되는 시점(매 3년째의 12월 31일까지를 말한다)마다 그 타당성을 검토하여 개선 등의 조치를 하여야 한다.

[별표 1] 침해사고 대응체계 수립 시 고려사항(제22조 관련)

구 분	주요 고려 사항
침해사고 대응·복구 절차 및 방법	○ 침해사고에 대한 복구 절차 및 방법 수립 시 고려 사항 - 침해사고의 정의 및 범위 - 긴급연락체계 구축 - 침해사고 발생 시 대응 요령 및 절차 - 침해사고 복구조직 구성 - 침해사고 복구 장비 및 자원 조달 - 침해사고 대응 및 복구 훈련 실시 사항
침해사고 보고	○ 침해사고 보고 시 고려 사항 - 침해 날짜와 시간 - 침해 사고 보고자 및 보고 일시 - 침해 사고 내용 - 침해 사고 대응 내역
침해사고 발생 시 응급조치	○ 침해사고 발생 후 응급조치 시 고려사항 - 손상된 시스템은 동작을 즉시 정지 - 내부망의 외부 접속을 즉시 차단 - 긴급복구가 즉시 수행되어야 하는 곳은 정보보호전문가에 의한 침입탐지 및 복구
침해사고 복구	○ 침해사고 복구 시 고려사항 - 사고원인의 분석 및 정의 - 필요한 경우, 재발을 방지하기 위한 대책의 수립 및 시행 - 정보자원 및 시스템 백업을 통한 시스템 재구축 방법 - 시스템 및 정보통신망에 대한 취약점 제거

[별표 2] 침해사고 예방조치 시 고려사항(제24조 관련)

가. 관리·운영 측면의 고려사항

구 분	주요 고려 사항
관리·운영절차	○ 관리·운영절차의 수립 시 고려사항 - 시스템 문제발생시 재동작 및 복구 절차 - 시스템 모니터링 방안 - 중요 산출물에 대한 관리 방안 - 업무수행 시 발생될 예외사항 및 오류사항 처리 방안 - 정보처리 및 취급 절차
제한구역 설정 및 보호	○ 제한구역 설정 시 고려 사항 - 보호대상 설정 - 특히 중요한 시설이나 장비는 제한구역으로 설정 - 출입 통제 방안 - 반출입 물품에 대한 기록 유지 - 정전대비 별도의 전원 공급 시설
장비·시설의 도입 및 설치	○ 시스템 구입 및 설치 시 일반적 고려 사항 - 현재 시스템의 성능과 가용능력의 한계에 대한 분석 - 시스템의 기능적, 운용적 요구사항 정의 및 시기의 예측 - 기존 시스템과의 적합성 확보 - 정보보호 시스템의 설치시는 보호지침과의 부합성 및 설치 필요성에 대하여 검증 - 정기적인 점검 및 안전성에 대한 재검토 ○ 정보보호시스템 도입 및 설치·운영 시 고려 사항 - 요구사항 파악 및 도입·설치의 목적 - 성능 및 도입·설치의 타당성에 대한 검토 - 관리의 편이성 및 로그관리의 편이성 - 정보보호시스템에 대한 로그 감시 기능
변경관리 절차	○ 장비, 소프트웨어, 절차들의 변경사항에 대한 관리 책임 및 절차 수립 시 고려사항 - 주요 변경사항 및 변경대상에 관한 정의·기록 유지 - 변경 실패에 따른 복구나 폐기에 대한 책임 정의 절차 - 변경에 대한 잠정적인 영향 평가 - 요구된 변경사항에 대한 승인절차 - 모든 관련자에게 변경사항에 대한 공지 및 교육

구 분	주요 고려 사항
로그 관리	○ 운영자 로그관리방안 수립 시 고려사항 - 시스템 시작, 종료시간, 사용자 인증실패, 접속 시도, 시스템 에러 및 수정 내용 등에 대한 로그 유지 - 로그 기록 방법, 대상, 보존 기간, 백업 등 - 주기적 로그 점검 및 방법 - 접근기록에 대한 정기적 분석 및 불법시도에 대한 조치 방법 - 보안 로그 기록 점검사항에 대한 주기적 보고 ○ 정보보호시스템의 로그 기록 시 필수 고려사항 - 성공적이거나 거부된 접속 - 정보보호시스템 구성요소로부터의 에러 메시지 - 다중 접근 시도 및 보안이 취약한 서비스 포트로의 접근 - 로그를 저장할 메모리 - 기록이 멈추게 되지 않도록 사전 대책 강구
장애 관리	○ 장애관리 시 고려사항 - 장애의 감지 및 복구를 위해 운영상황 감시 기능 설정 - 장애관리 보고 절차 수립 - 전체시스템에 대한 피해 최소화를 위해 장애치단 및 장애복구 기능 설정 - 장애처리 후 로그에 대한 재점검으로 장애의 완전 복구상태 확인
저장매체 관리	○ 테이프, 디스켓, 출력보고서 등의 저장매체 관리 시 고려 사항 - 저장매체에 대한 목록관리, 분류, 접근통제, 보관 장소, 보관기간, 보관절차 등 수립 - 저장매체에 대한 복사, 변경, 배포, 폐기 방안 - 저장매체 정보저장, 취급 및 전달 절차 수립 - 저장매체 사용에 대한 허가, 점검 수립 및 기록유지 - 저장매체 저장 내용 삭제·폐기 절차
악의적 소프트웨어 관리	○ 컴퓨터바이러스 등 악의적 소프트웨어로부터의 보호를 위한 통제·탐지 조치 시 고려 사항 - 사용자에게 바이러스의 위험성에 대한 인식 필요 - 비인가 및 불법 소프트웨어 사용금지 - 알려진 바이러스 백신프로그램 사용 - 지속적인 바이러스 백신프로그램 업데이트 및 검사 - 검증되지 않은 저장매체는 사용 전에 검사 - 외부 네트워크나 매체로부터 파일 또는 소프트웨어 다운로드 시 대책 마련
백 업	○ 시스템, 데이터, DB 등 정보자산에 대한 백업조치 시 고려 사항 - 정보자산에 대한 장애 대비 백업 및 복구 절차 규정 - 데이터 중요도에 따른 백업 대상, 백업 방식, 백업주기, 백업기준 등 설정 - 자연재해로부터 보호받을 수 있는 안전한 장소에 대한 지정 - 주기적으로 백업 받은 데이터에 대한 복구 테스트 실시 - 중요정보에 대하여는 제3의 장소 등 물리적으로 분리된 곳에 백업데이터 보관

나. 기술적 측면에서의 고려사항

구 분	주요 고려 사항
사용자 관리	○ 사용자 계정 관리 시 고려 사항 - 시스템 접근에 대한 공식적인 사용자 등록 및 해지 절차 수립 - 주기적으로 인가된 사용자 여부 및 접근권한 점검 - 사용자의 공식적인 로그를 보관 - 동일사용자 계정의 다른 사용자 계정 재발급 방지 - 시스템 관리자가 일반 업무 시 일반 사용자 계정 사용
패스워드 관리	○ 패스워드 관리 시 고려사항 - 책임 추적성을 위해 패스워드 할당 - 패스워드의 안전한 보관 - 패스워드의 노출가능성이 있으면 즉시 변경 - 패스워드 설정 시 기피해야 할 요건 . 특정 달, 요일, 머리글자, 주민등록번호, 자동차번호 . 회사이름, 전화번호 또는 비슷한 숫자 그룹 . 2개 이상의 연관된 신원확인 가능 문자, 숫자, 영문 알파벳 그룹 - 주기적으로 패스워드를 변경, 지난 패스워드 사용금지 - 특별권한이 부여된 ID의 패스워드는 정기적으로 점검 - 첫 로그인 시 임시 패스워드는 변경 - 비밀번호 오류 횟수의 제한
네트워크 접근 통제	○ 네트워크 접근 통제 시 고려 사항 - 네트워크로 접근하는 사용자에 대한 인가 절차 - 원격접속 사용자 인가 절차 - 비인가된 접근을 막기 위해 서비스 경로의 제한 및 분리 - 관계회사 등과 네트워크 공유 시에는 물리적 또는 논리적으로 분리 - 원격 장비의 관리를 위한 책임 및 절차를 수립 - 개발업무 네트워크와 다른 업무용 네트워크와의 분리 운영 - 인증, 암호 활용을 통한 원격 접속 사용자에 대한 접근통제 - 네트워크를 통해 시스템 운영 시 시스템 관리는 원칙적으로 내부 특정 단말로 제한

[별표 3] 정보보호책임자, 정보보호실무책임자 통보 서식(제5조 및 5조의2 관련)

구분	관리 기관명	기반 시설명	소속	직책 /직급	성명	변경일자	연락처 (사무실/ 휴대폰)	메일주소

[별표 4] 자산 관리대장(제6조 관련)

관리 번호	시스템명	장비명	제조업체	관리자	도입연도	OS버전/ 설치일자	주요 프로그램	백신	설치 장소	지정 일자

※ 자산관리대장은 기반시설 특성, 운영환경 등 기관에서 필요한 항목을 추가/삭제/보완하여 사용

[별표 5] 점검항목별 조치 이력관리대장(제17조 관련)

- 관리기관명 :
- 기반시설명 :

시스템명	분류	코드 번호	점검 항목	중요도 (등급)	진단결과		취약점 유형	조치 계획	조치기간 변경사유	최종 조치일	미조치 또는 신규취약점 사유		미조치에 대한 보안대책 및 세부내용
					전년	당해					분류	세부내용	
온나라 DB#1	계정 관리	U-01		상	취약	취약	기존	단기			서비스 영향		
				중	양호	취약	신규	장기			시스템 교체		

< 이력관리대장 작성방법 >

※ 작성대상 : 전년도 또는 해당 연도 취약한 항목(모두 양호한 경우 작성 불필요)

1. 시스템명 : 정보시스템을 구별할 수 있도록 구체적인 명칭 기재

2. 분류 : 주요정보통신기반시설 취약점 분석·평가 기준(과학기술정보통신부 고시)의 취약점 점검 분류(관리적, 물리적, 기술적 점검 분류항목 기재) 기재

3. 코드번호 : 주요정보통신기반시설 취약점 분석·평가 기준(과학기술정보통신부 고시)의 취약점 분석·평가 항목의 분류별 번호 기재

4. 점검항목 : 해당 취약점에 대한 점검내용 기재

5. 중요도 : 주요정보통신기반시설 취약점 분석·평가 기준의 위험등급 기재(상/중/하)

6. 진단결과 : 해당 취약점 점검 결과 기재(양호/취약) *N/A 및 즉시 조치는 ‘양호’로 기재

7. 취약점 유형 : 전년 대비 취약점 유형 기재(기존/신규/양호)

8. 조치계획 : 해당 취약점 점검 결과 기재(양호/취약/부분취약)

9. 조치기간 변경사유 : ‘상’ 등급 취약점은 단기로 조치해야 하나 ‘중기/장기/조치불가’ 등으로 변경한 경우 사유 기재

10. 최종점검(조치) 일자 : 마지막으로 점검(조치)한 날짜

11. 미조치 또는 신규 취약점 사유 : 구체적인 사유 기재

12. 미조치에 대한 보안대책 및 상세내용 : 보안대책과 상세내용을 기재

[별표 6] 보안관리실태 점검표(제18조 관련)

□ 제어시스템 보안관리 점검표

순번	점검 내용	확인
1	제어시스템은 업무망·인터넷 등 외부망과 물리적으로 분리·운영하고 외부망과 연결접점이 없는가?	
2	비인가 PC·서버 및 네트워크의 접속을 차단하였는가?	
3	제어망에서 업무망으로 자료전송을 위한 일방향 전송장비 또는 침입차단시스템 운영시 보안정책 설정이 적절한가?	
4	각종 시스템에 사용자별 또는 그룹별로 접근권한을 부여하였는가?	
5	비밀번호 사용시 숫자, 문자, 특수문자를 혼합하여 9자리 이상을 사용하고 있는가?	
6	제어시스템 및 관련 장비 도입시 보안 요구사항에 따른 검증을 실시하였는가?	
7	정보시스템 자산에 대해 최신 현황을 유지하고 있는가?	
8	중요자료는 대외비 이상으로 생산하여 독립PC 또는 보안USB 보관, 암호화 등 안전하게 관리하고 있는가?	
9	PC·서버에 불필요한 서비스 포트 제거 및 공유 금지를 하고 있는가?	
10	PC·서버에 제어시스템 운영 관련 프로그램만 설치하고 불필요한 프로그램은 제거하였는가?	
11	PC·서버에 USB 자동실행 기능을 차단하고 있는가?	

12	서버·정보보호시스템·네트워크 장비 등에 사고발생시 추적을 위한 접근기록을 1년 이상 보관하고 있는가?	
13	USB·LAN포트를 잠금장치·보안스티커 등을 사용하여 물리적으로 봉인하고, 봉인장치 개폐시 사용내역을 기록 유지하고 있는가?	
14	PC·서버에 최신 백신 프로그램을 설치하고 전수검사를 하였는가?	
15	백신 프로그램을 설치할 수 없는 단말기에 대해 프로세스 점검, 비인가 기기 접속여부 등을 점검하였는가?	
16	PC·서버의 운영체제 등 S/W에 대해 최신 보안패치를 하였는가?	
17	자료 전송시 광디스크를 사용하거나 지정된 전용단말기를 사용하고 있는가?	
18	‘클린PC’ 사용시 백신 검사, 특정사이트로 접속 제한 등 보안조치를 하였는가?	
19	제어시스템에 USB 사용을 금지하고 있는가?	
20	휴대용 저장매체 관리대장을 현행화하고 관리실태를 점검하였는가?	
21	휴대용 기기에 대한 반·출입 통제를 하고 있는가?	
22	외부에서 반입·사용하는 정보통신기기에 대해 포맷 후 필요한 프로그램만 설치 등 보안조치 하였는가?	
23	취약점 분석·평가 및 보호대책 이행여부 확인 결과 발견된 문제점을 보완조치 하였는가?	
24	사이버위기를 가정한 대응 모의훈련을 실시하고 비상대비체계의 정상작동 여부를 점검하였는가?	

□ 정보시스템 보안관리 점검표

순번	점검 내용	확인
1	웹서버 등 외부 공개용 서버는 DMZ 구간에, DB서버 등 중요 서버는 내부 구간에 위치하는 등 네트워크 구성이 적절한가?	
2	정보시스템은 다른 정보통신망(인터넷 포함)과 분리 운영하고 있는가?	
3	정보시스템 연결 업무망 PC는 인터넷과 분리되어 있는가?	
4	정보시스템과 원격지 연결은 전용회선 또는 가상사설망 구축 등 안전한 수단을 활용하고 있는가?	
5	비인가 PC·서버 및 네트워크의 접속을 차단하였는가?	
6	각종 시스템에 사용자별 또는 그룹별로 접근권한을 부여하였는가?	
7	비밀번호 사용시 숫자, 문자, 특수문자를 혼합하여 9자리 이상을 사용하고 있는가?	
8	네트워크 트래픽 보안정책이 적절하게 설정되어 있는가?	
9	정보시스템 자산에 대해 최신 현황을 유지하고 있는가?	
10	중요자료는 대외비 이상으로 생산하여 독립PC 또는 보안USB 보관·암호화 등 안전하게 관리하고 있는가?	
11	백업시스템에 대해 보안점검을 실시하였는가?	
12	PC·서버에 정보시스템 운영 관련 프로그램만 설치하고 불필요한 프로그램은 제거하였는가?	

13	서버·정보보호시스템·네트워크 장비 등 시스템에서 불필요한 서비스 포트 및 원격연결 서비스를 통제하였는가?	
14	불필요한 공유폴더 또는 비인가 파일서버 사용을 통제하였는가?	
15	PC·서버에 USB 자동실행 기능을 차단하였는가?	
16	서버·정보보호시스템·네트워크 장비 등에 사고발생시 추적을 위한 접근기록을 1년 이상 보관하고 있는가?	
17	서버·정보보호시스템·네트워크 장비 등 시스템에 대한 접근통제 정책을 점검, 갱신하였는가?	
18	PC·서버에 최신 백신 프로그램을 설치하고 전수검사를 하였는가?	
19	PC·서버의 운영체제 등 S/W에 대해 최신 보안패치를 하였는가?	
20	백신 및 패치 관리서버에 대해 업데이트를 실시하고 악성코드 감염 여부 및 접속기록을 점검하였는가?	
21	휴대용 저장매체 관리대장을 현행화하고 관리실태를 점검하였는가?	
22	휴대용 기기에 대한 반·출입 통제를 하고 있는가?	
23	웹서버의 최신 웹 취약점을 제거하였는가?	
24	정보시스템에 대한 외부 침해시도 여부를 모니터링하고 로그자료를 분석하였는가?	
25	취약점 분석·평가 및 보호대책 이행여부 확인 결과 발견된 문제점을 보완조치 하였는가?	

[별표 7] 용역사업 보안 점검표(제27조 관련)

용역사업 보안 점검표

○ 입찰 및 계약시

구분	보안 대책	확인
사업 착수 및 입찰시	중요 정보화 사업의 경우 사업 착수단계부터 사업계획 전반에 대해 적정등급의 비밀 또는 대외비로 분류	
	입찰 공고 이전에 보안관리가 필요한 자료·장비에 대해 투입이전에 관련법규에 따라 등급을 분류하고 필요한 요구사항을 마련	
	입찰 공고 시 누출금지 대상정보, 부정당업자 제재조치, 기밀유지의무 및 위반 불이익 등에 대해 정확히 공지	
	제안서 평가요소에 보안관리 계획에 대한 평가항목 및 배점기준 마련	
	제안서에서 제시한 용역사업 전반에 대한 보안관리 수행계획의 타당성 검토	
	웹호스팅 등 정보시스템 위탁 운영시 정보보호시스템 구비 및 보안관리 가능 여부 검토	
사업 계약시	발주기관의 요구사항이 과업지시서·계약서에 명확히 명시될 수 있도록 중요 항목(보안조치·누출금지대상·제재조치)을 정확히 기술	
	용역업체가 사업에 대한 하도급 계약을 체결한 경우 원래 사업계약수준의 비밀유지 조항 포함	
	대외보안 필요시 비밀유지 계약서에 비밀정보 범위, 보안 준수사항, 위반시 손해배상 책임, 지적재산권 문제, 자료 반환 등 중요항목 명시	

○ 사업 수행시

구분	보안 대책	확인
인원 및 물리적 보안 관리	사업 참여인원 신원확인 실시	
	사업 참여인원 보안서약서 징구	
	사업 수행 전 참여인원에 대해 비밀유지 의무 준수·누출금지 대상 정보·위반시 처벌내용 등에 대한 보안교육 실시	
	사업 수행 중 참여인원에 대한 보안점검을 실시하여 '누출금지 대상정보'의 외부 누출여부 확인	
	발주기관 내부: 시건장치와 통제가 가능한 공간 제공 여부 발주기관 외부: CCTV·시건장치 등 비인가자 출입통제 대책이 마련된 외부 사무실 이용 여부	
	CCTV 등 통제장치의 관리상태(작동여부, 사각지대 보완 등) 및 기록 확인	
전산망 보안 관리	업체 사용 전산망은 방화벽 등을 활용하여 기관 업무망과 분리구성하고 업무상 필요한 서버에만 제한적 접근 허용	
	업체 PC 인터넷 연결 차단여부 및 인터넷 접속허용 PC에 대한 보안 조치	
	비인가 무선 AP(무선공유기, 스마트폰 핫스팟 등) 설정을 금지하고 휴대형 무선모뎀(Wibro, HSDPA, WiFi 등)반입 통제	
	스마트폰·휴대폰을 무선 모뎀으로 활용하지 못하도록 통제수단 강구(PC에 비인가 통신기기 접속차단 S/W설치, 스마트폰 접속단자 봉인조치 등)	
	노트북PC 반입시 무선통신 기능 불능화 조치(driver 삭제 등) 시행	
	기관 외부에서 기관 내부의 시스템 개발 PC 및 기관 시스템에 원격접속 금지	
	업체 직원의 계정은 하나의 그룹으로 등록하고 계정별로 정보시스템 접근권한을 부여하되 기관 내부문서 접근 금지	
	업체 직원의 'root' 계정 등 시스템에 중대한 영향을 끼칠 수 있는 계정에 대한 단독 접근 금지	
	계정별로 부여된 권한은 불필요시 곧바로 해지하거나 계정 폐기	
	업체 직원의 작업내용 확인을 위해 작업이력 로깅기능 구축	
	사업 책임자는 서버 및 장비 운영자로 하여금 내부서버 및 네트워크 장비에 대한 접근기록을 매일 확인하여 이상 유무 보고	

구분	보안대책	이행 실태
자료 보안 관리	계약서 등에 명시한 누출금지 대상정보를 업체에 제공할 경우, 자료 인계인수대장을 작성하고, 인계자·인수자가 자필로 서명한 후 제공	
	사업 관련 자료는 웹하드, P2P, 웹오피스, 클라우드 서비스 등 인터넷 자료공유사이트 및 개인 메일함에 저장 금지	
	사업 관련자료 및 모든 산출물은 기관의 파일서버에 저장하거나 사업 책임자가 지정한 PC(인터넷 연결차단)에 저장 및 관리	
	발주기관이 제공한 사무실에서 사업을 수행할 경우 기관이 제공한 비공개 자료는 매일 퇴근시 반납	
	사업 수행으로 생산되는 산출물 및 기록은 비인가자에게 제공, 대여, 열람 금지	
	비밀번호는 정보보안담당관이 별도로 기록·관리하고 수시로 해당 계정에 접속하여 저장된 자료와 작업이력 확인	
전산 장비 및 매체 보안 관리	업체 전산장비는 보안담당관 승인 후 반입·반출 * 반출시 보안담당관 통제하에 저장자료 완전 삭제	
	전산장비 반입·반출시마다 악성코드 감염여부 점검 및 자료 무단 반출입 여부 확인	
	업무망 접속용 전산장비와 인터넷망 접속용 전산장비를 구분하여 활용 및 망간 혼용 금지	
	업체 노트북PC, 휴대용 저장매체 정기 보안점검	
	업체 휴대용 저장매체 사용이 불가필할 경우 보안담당관 승인 후 사용	
	노트북·PC, 휴대용 저장매체는 시건장치가 있는 보관함에 보관	
	인터넷망 접속이 필요한 전산장비사전 지정 및 보안조치 실시	
	업무에 필요한 사이트에만 접속토록 방화벽 등을 통해 통제 * P2P, 웹하드, 메신저 등 인터넷 자료공유사이트 활용 원천차단	
	인터넷 접속허용 전산장비에 사업 관련 자료 저장 금지	
	최신 백신 프로그램 설치 및 주기적인 전체 파일 검사 실시	
	비밀번호·화면보호기 설정 및 정기적 변경	
	비인가 저장매체·통신기기 접속 통제 * 매체제어 미설치 전산정비는 외부기기 연결단자 보안스티커 부착	

○ 완료 단계

구분	보안대책	이행 실태
용역 사업 완료시	사업 완료 후 생산되는 최종 산출물 중 대외보안이 요구되는 자료에 대해 대외비 이상으로 작성·관리하고 불필요한 자료는 삭제 및 폐기	
	업체에게 제공한 사업과 관련된 제반자료는 전량 회수 및 자료관리대장에 기록하고 업체는 복사본 별도 보관 금지	
	업체에 복사본 등 사업 관련 자료를 일체 보유하고 있지 않다는 업체 대표 명의의 보안확약서를 징구	
	업체 소유 PC·서버의 하드디스크, 휴대용 저장매체 전자기록저장매체는 검증필 삭제S/W로 완전 삭제, 보안담당자 승인 후 반출	
	업체에서 설정한 정보시스템의 계정과 비밀번호 변경조치	

[별표 8] 주요정보통신기반시설 장비현황 라벨(제6조의2 관련)

< 기반시설 장비현황 라벨 >



< 장비현황 라벨 작성방법 >

1. 기반시설명 : 해당 관리기관에 지정된 기반시설의 시스템 명칭 기재(예, oo상수도 정수제어시스템)
2. 관리부서 : 해당 기관내 기반시설에 대한 보호업무를 담당하는 부서 기재
3. 관리번호 : 장비별 고유 일련번호 기재(별표4 자산관리대장과 일치되게 작성)
4. 담당자 : 해당 주요정보통신기반시설의 보호담당자
5. 장비명 : 장비명칭 기재(예, 운전제어PC)
6. 모델명 : 해당 장비의 제조사 모델명 기재(삼보 TG 2500)
7. 설치일자 : 해당 장비를 설치한 일자 기재(기반시설 지정일자와 상이할 수 있음)

[별표 9] 주요정보통신기반시설 세부시설 지정기준(제6조 관련)

분야	지정단위	세부시설 지정기준(필수)	선택 세부시설
도시철도 경전철	철도운영종합관제시스템 (신호관제시스템, 전력관제 시스템, 통신관제시스템)	종합관제소 내 신호관제, 전력관제 및 통신관제를 위해 운영되는 서버, PC, 네트워크, 보안, 제어컨트롤러, 통신설 비 등 모든 시스템	Serial통신방식의 설비, 기계설비제어시스템, 현 장 역사 내 서버, PC 등
교통신호	교통신호제어시스템	교통신호제어, 조회, 저장을 위해 운 영되는 서버, PC, 네트워크, 보안, 통 신설비 등 모든 시스템	교차로 신호제어기 등
스마트도시	스마트도시 통합운영시스템	스마트도시 통합플랫폼, CCTV 영상 관제 및 저장 등을 위해 운영되는 서 버, PC, 네트워크, 보안 장비 등 모든 시스템	스마트 서비스 관련 기 타 시스템 등
정수제어	상수도정수제어시스템	정수센터내 정수처리 관련 정보수집, 감시, 제어조작을 위해 운영되는 서 버, PC, 네트워크, 보안, 제어컨트롤 러, 통신설비 등 모든 시스템	Serial통신방식의 설비, 원격지의 현장 설비
물재생공정	물재생공정제어시스템	물재생센터 내 하수처리 관련 정보수 집, 감시, 제어조작을 위해 운영되는 서버, PC, 네트워크, 보안, 제어컨트롤 러, 통신설비 등 모든 시스템	Serial통신방식의 설비, 원격지의 현장 설비
지역난방	지역난방제어시스템	발전소내 열공급설비 관련 운전정보 저장, 제어를 위해 운영되는 서버, PC, 네트워크, 보안, 제어컨트롤러, 통 신설비 등 모든 시스템	Serial통신방식의 설비, 원격지의 현장 설비
인터넷 및 업무	인터넷 및 업무시스템	광역시도의 내·외부 백본네트워크시스 템, 내·외부 보안시스템, 대표홈페이 지, 시도행정, 전자결재시스템 및 해 당 시스템 관리를 위해 운영되는 관 리용 PC	필수 외 시스템

※ 기반시설의 지정단위 및 세부시설의 지정은 기반시설 운영환경 등에 따라 조정 가능

[별표 10] 주요정보통신기반시설 사고신고서(제21조 관련)

사 고 신 고 서

기 본 정 보			
기 관 명		부 서	
성 명		직 위	
전자우편			
연 락 처			
사 고 내 용			
사고 일시		피해IP주소	
피해시스템 용 도		운영체제	
사고 유형		피해범위	
사고 내용			
조 치 내 용			
공격자 정보			
피해 증상			
긴급조치 실시사항			
관련보안제품 운영현황			
그 밖에 사고 관련 내용을 구체적으로 서술			

o 시스템 분류 목록

기호	시스템 분류	설명
가	웹서버	기관의 홈페이지 운영 및 웹서비스를 제공하는 서버
나	전자우편 서버	전자우편 송수신을 위해 운영하는 서버
다	DB/업무서버	홈페이지 및 업무지원을 위한 데이터베이스 서버
라	개발/임시서버	개발 및 운영 테스트를 위하여 사용하는 임시 서버
마	통신전송장비	라우터, 스위치 등 통신전송장비 일체
바	보안장비	방화벽, IDS, VPN 및 백신서버 등 정보보안제품 일체
사	개인/업무PC	기관내 사용자의 PC
아	교육/임시PC	교육장 또는 공용 작업을 위해 여러 명이 사용하는 PC
자	기타	위의 시스템 용도에 없는 경우 서술식으로 기술

o 사고 유형 목록

기호	사고 유형	설명
A	경유지 악용	타기관으로부터 해킹 시도 항의를 받았거나, 시스템 점검 중 해킹 흔적 또는 해킹툴이 설치되어 타시스템에 접속한 기록이 발견되었을 경우
B	자료훼손 및 유출	내부 시스템의 자료가 변조가 되었거나, 대량의 데이터가 외부로 무단 송신된 흔적이 발견되었을 경우
C	단순침입 시도	지속적인 스캐닝 공격이 발생할 경우
D	웜바이러스 피해	기관내의 PC에서 웜바이러스가 발견되었을 경우
E	홈페이지 변조	기관의 홈페이지가 변조되었을 경우
F	홈페이지 접속 불가능	기관의 홈페이지 서버 또는 네트워크 이상으로 인해 홈페이지 접속이 불가능 할 경우
G	서비스거부공격 피해	불특정 다수의 IP로부터 접속 시도 또는 대량 트래픽이 일시에 유입될 경우
H	기타	위의 사고유형에 포함되지 않을 경우 서술식으로 기술

[별표 11] 주요정보통신기반시설 조치결과서(제22조 관련)

조치결과서

기 본 정 보			
기 관 명		부 서	
성 명		직 위	
전자우편			
연 락 처			
사 고 내 용			
사고 일시		피해IP주소	
피해시스템 용도		운영체제	
사고 유형		피해범위	
사고 내용			
조 치 내 용 요 약			
사고 원인			
피해 증상			
사고대응 조치사항			
피해복구결과			
기 타			
* 자세한 사항은 사고원인·피해 증상·조치내역·향후개선대책 등을 망라하여 ‘사고처리결과보고서’ 작성			